

praisonai-platform: IDOR in dependency endpoints allows cross-workspace issue linking, reading, and deletion due to missing ownership checks

Report Type: Weekly · Generated: May 31, 2026 05:30 UTC · Coverage: May 29 – May 31, 2026

1	0	1	0
Total Advisories	Critical	High	Medium

Executive Summary

Summary **Type:** Insecure Direct Object Reference. The dependency endpoints (`POST/GET /workspaces/{workspace\_id}/issues/{issue\_id}/dependencies` and `DELETE .../dependencies/{dep\_id}`) gate access on `require\_workspace\_member(workspace\_id)` only, then dispatch to `DependencyService` calls that take URL/body-supplied issue and dependency IDs without verifying any of them belong to the membership-checked workspace. Most damaging: `create\_dependency` accepts `body.depends\_on\_issue\_id` from the request body — that ID is checked against nothing — letting an attacker create a "blocks" or "related" link between any two issues anywhere in the database. **File:** `src/praisonai-platform/praisonai\_platform/api/routes/dependencies.py`, lines 22-58; `services/dependency\_service.py`, lines 26-65. **Root cause:** the same `Depends(require\_workspace\_member)` default-min-role pattern as the companion IDORs, plus a service layer (`DependencyService`) where every method takes raw IDs and queries t

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
prisonai-platform: IDOR in dependency endpoints allows cross-workspace —	LOW	3.1	0.00000	## Summary **Type:** Insecure Direct Object Reference. The dependency

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Attribution analysis across advisories in this report period.

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for praisonai-platform: IDOR in dependency endpoints allows cross-workspace issue linking, reading, and deletion due to missing ownership checks.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK techniques.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--57498c137dec
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T05:30:23.316245+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.